

PIN lock — how login protection works

Short product note for PO: after repeated wrong PINs, the account is temporarily locked. Flutter can show a countdown from the API response.

Rules (agreed)

- User-based lock (not device / IP).
- Wrong PIN counter lives in a 10-minute window.
- 3 wrong PINs inside that window → lock for 6 minutes.
- While locked: even a correct PIN is rejected (option A).
- Successful login clears the counter and any lock.
- If the next wrong PIN comes after 10+ minutes, counter restarts at 1.

What the user / app sees

200	Correct PIN, not locked → login success (tokens)
401	Wrong PIN (1st or 2nd in the window)
423	Account temporarily locked — show countdown

423 response (for Flutter countdown)

Body fields

- error: "PIN_LOCKED"
- message: localized text (AZ / EN / RU)
- lockedUntil: timestamp when unlock happens
- remainingSeconds: seconds left (use for timer UI)
- status: 423

Simple timeline example

Scenario

- 12:00 wrong → 401 (attempt 1)
- 12:02 wrong → 401 (attempt 2)
- 12:03 wrong → 423 locked until 12:09
- 12:05 correct PIN → still 423 (must wait)
- 12:09+ correct PIN → 200 login success
- OR: 12:00 wrong, then 12:15 wrong → counter = 1 again (window expired)

Config knobs

- max attempts: 3
- attempt window: 10 minutes

- lock duration: 6 minutes
- status field stays ACTIVE — temporary lock uses separate timestamps

Endpoint: POST /api/v1/users/login · No change to public URL. Only login behaviour + error payload for lock.